EvidenceOps｜SOC 2 Type I 14 天 PoV（一頁式簡報）

主標

EvidenceOps：14 天交付 SOC 2 Type I 稽核佐證樣張（PoV）
(EvidenceOps: SOC 2 Type I evidence sample in 14 days)

副標

用「最少干擾」把稽核需要的佐證拉齊：**控制項對應、佐證清單、擷取方式、可追溯的稽核軌跡**。

適用對象（Who it’s for）

- 資安/治理：資安主管、GRC/Compliance、內控/稽核窗口
- IT/雲端：Google Workspace 管理員、IAM/維運
- 工程/交付：Engineering Manager、DevOps/SRE、平台團隊、PM/PMO
- 正在面對：SOC 2 / ISO 27001 / 客戶供應商資安審查

PoV 範圍（14 天 / 10 控制項 / 3 系統）

期間：14 天

- D1–D3：Kickoff、盤點資料、權限開通、控制項與佐證需求對齊
- D4–D10：佐證蒐整/彙整、標準化產出、缺口標記、建立可追溯鏈
- D11–D14：結果回顧、改善建議、移交與下一步路線圖

控制項：10 項（以 SOC 2 CC 系列為主，可映射 ISO27001）

- 以高頻稽核主題優先：身分與存取、MFA、最小權限、變更管理、PR 審查、日誌稽核軌跡、事件處理、風險與政策、供應商/第三方治理等

資料來源：Google Workspace + GitHub + Jira

- Google Workspace：管理設定、使用者/群組、存取政策、稽核日誌（依可用性）
- GitHub：權限/Teams、分支保護、PR 審核、CI 狀態、Audit log（依方案）
- Jira：變更票據、核准軌跡、與 PR/部署關聯（可追溯性）

交付物（Deliverables）

1. **佐證盤點報告（Evidence Inventory）**：每項控制要什麼佐證、從哪裡來、可得性、缺口/風險
2. **控制項 ↔ 佐證對照矩陣（Mapping）**：可對應 SOC 2 / ISO 條文
3. **佐證包樣張（Evidence Pack Sample）**：可交付稽核員閱讀的格式（含來源、時間戳、證據鏈敘述）
4. **擷取方式（Scripts / Queries / 匯出步驟）**：以可重跑為原則，附操作說明與最小權限
5. **缺口與改善建議（Gap + Quick wins + Roadmap）**
6. **交接（Handover）**：60–90 分鐘交付說明會（重跑方式、更新頻率建議）

驗收標準（Acceptance criteria）

- 10 項控制項皆具備「**佐證來源 + 產出格式 + 取得步驟**」
- 每份佐證可回溯到來源系統、時間戳、擷取方式（人工/自動）
- 至少核心佐證擷取流程可重複執行（含操作文件或腳本）

- 缺口明確：原因（權限/方案限制/資料不存在）＋替代方案
- 完成一次佐證包交付與回顧，可用於稽核準備/內稽演練

權限與資料處理聲明（Access & data handling）

- **最小權限原則**：預設以唯讀/稽核查詢為主；如需變更設定，須由客戶端執行或明確授權並留痕
- **資料最小化**：僅蒐集完成佐證所需的設定、事件、稽核紀錄與匯出報表
- **敏感資料**：可遮罩（masking）/ 最小化欄位 / 或採「客戶端產出、我們只拿結果」模式
- **保密**：可配合 NDA；不將客戶資料用於訓練或再利用（可明載於條款）

FAQ（常見問題）

Q1：14 天能做到什麼？會不會只是做報告？
A：PoV 的目標是把佐證做到「可交付、可重跑」——會產出佐證包樣張與擷取方式，並列出缺口與下一步。

Q2：權限很嚴格，還能做嗎？
A：可以。我們以最小權限進行；若因權限/方案限制無法取得，會提供替代佐證或補強建議。

Q3：資料外流風險怎麼控？
A：預設必要最小化收集，可採客戶端產出模式；並提供遮罩與保存/刪除約定，搭配專用帳號、到期權限與存取留痕。

聯絡方式（Contact）

- Email：evidenceopsco@gmail.com
- Website：https://evidenceopsco.github.io/ （中文：https://evidenceopsco.github.io/zh/）
- PoV 需求表：
  https://docs.google.com/forms/d/e/1FAIpQLSdnrkjzy9IFTtMSmAmxPi7GMsTQfgXEnxtkjjBPmexbNM1qLg/viewform

---

頁腳一句話：把稽核變成工程問題：可追溯、可重跑、可持續。